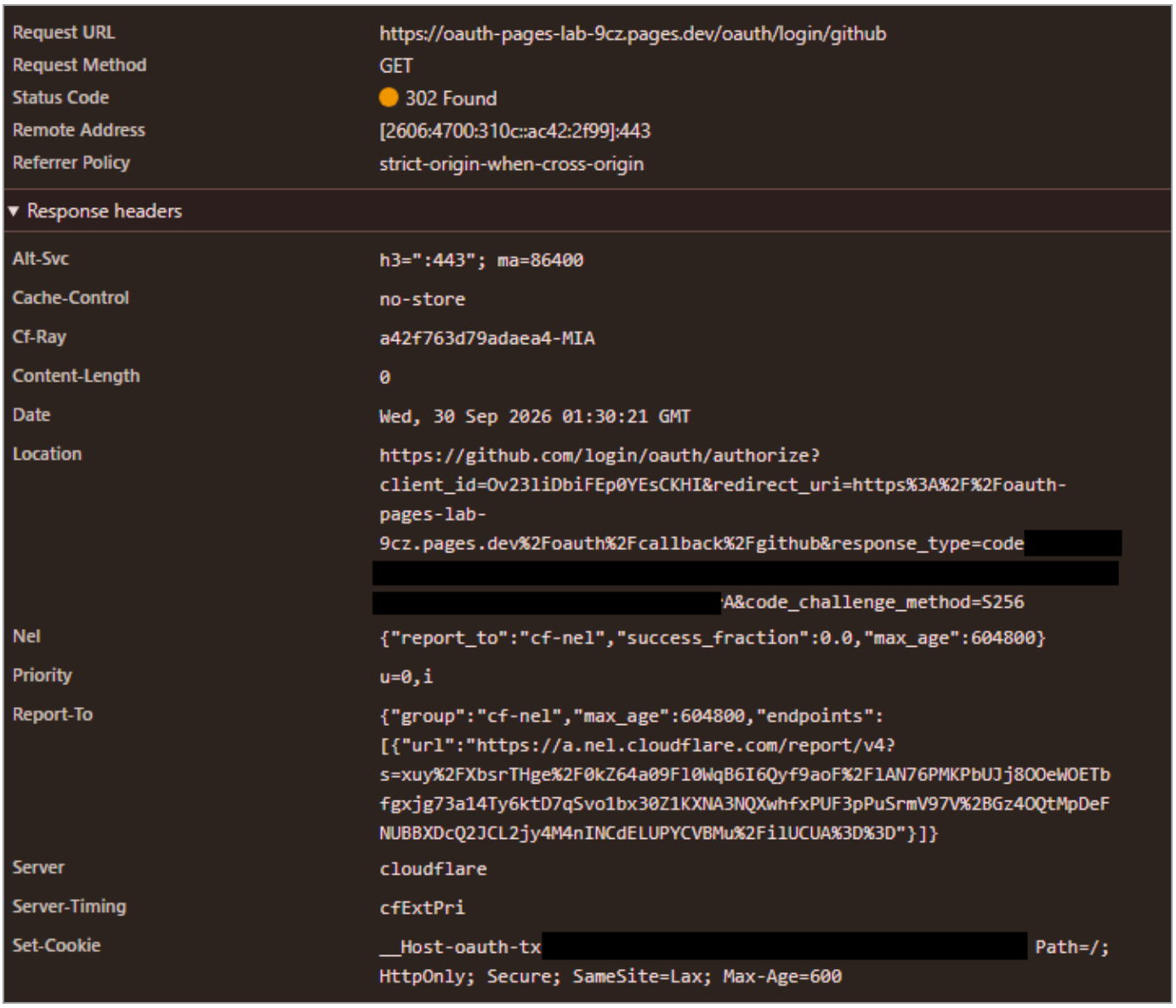
06 - Cabecalhos saneados do inicio do login com GitHub

Laboratorio: login em um site estatico no Cloudflare Pages

Autoria: trabalho individual — Joao Vitor do Nascimento Martins, RA 2016108385

> Documento de evidencia saneado. As capturas do DevTools mostram a resposta e a requisicao reais da implantacao de producao; os valores transitorios (cookie __Host-oauth-tx, state e code_challenge) foram ocultados com tarja preta. O Client ID aparece apenas por ser publico por definicao OAuth; o Client Secret e o code_verifier nao existem nesta rota.

Captura 1: resposta 302 de /oauth/login/github



Request URL	https://oauth-pages-lab-9cz.pages.dev/oauth/login/github
Request Method	GET
Status Code	302 Found
Remote Address	[2606:4700:310c::ac42:2f99]:443
Referrer Policy	strict-origin-when-cross-origin

▼ Response headers

Alt-Svc	h3=":443"; ma=86400
Cache-Control	no-store
Cf-Ray	a42f763d79adaea4-MIA
Content-Length	0
Date	Wed, 30 Sep 2026 01:30:21 GMT
Location	https://github.com/login/oauth/authorize?client_id=Ov231iDbiFEp0YEsCKHI&redirect_uri=https%3A%2F%2Foauth-pages-lab-9cz.pages.dev%2Foauth%2Fcallback%2Fgithub&response_type=code[redacted]A&code_challenge_method=S256
Nel	{"report_to":"cf-nel","success_fraction":0.0,"max_age":604800}
Priority	u=0,i
Report-To	{"group":"cf-nel","max_age":604800,"endpoints":[{"url":"https://a.nel.cloudflare.com/report/v4?s=xuy%2FXbsrTHge%2F0kZ64a09Fl0WqB6I6Qyf9aoF%2FlAN76PMKPbUJj8OOeWOETbfgxjg73a14Ty6ktD7qSvo1bx30Z1KXNA3NQXwhfxPUF3pPuSrmV97V%2BGz4OQtMpDeFNUBBXDcQ2JCL2jy4M4nINCdELUPYCVBMu%2FilUCUA%3D%3D"}]}
Server	cloudflare
Server-Timing	cfExtPri
Set-Cookie	__Host-oauth-tx[redacted] Path=/; HttpOnly; Secure; SameSite=Lax; Max-Age=600

Response headers com Location apontando para github.com/login/oauth/authorize, Set-Cookie __Host-oauth-tx (Path=/, HttpOnly, Secure, SameSite=Lax, Max-Age=600) e Cache-Control: no-store. Valores de state, code_challenge e do cookie ocultados com tarja.

Captura 2: requisicao de /oauth/login/github (cookie temporario)

:authority	oauth-pages-lab-9cz.pages.dev
:method	GET
:path	/oauth/login/github
:scheme	https
Accept	text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding	gzip, deflate, br, zstd
Accept-Language	pt-BR,pt;q=0.9,en-US;q=0.8,en;q=0.7,es;q=0.6
Cache-Control	no-cache
Cookie	__Host-oauth-tx=C[redacted]
Pragma	no-cache
Priority	u=0, i
Referer	https://oauth-pages-lab-9cz.pages.dev/
Sec-Ch-Ua	"Chromium";v="154", "Google Chrome";v="154", "Not A(Brand";v="99"
Sec-Ch-Ua-Mobile	?0
Sec-Ch-Ua-Platform	"Windows"
Sec-Fetch-Dest	document
Sec-Fetch-Mode	navigate
Sec-Fetch-Site	same-origin
Sec-Fetch-User	?1
Upgrade-Insecure-Requests	1
User-Agent	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/154.0.0.0 Safari/537.36

Request headers do navegador enviando apenas o cookie temporario __Host-oauth-tx (valor ocultado) para a mesma origem; nenhuma credencial e enviada.

Parametros do pedido de autorizacao (visiveis na captura 1)

Parametro	Valor / conferencia
client_id	Ov23liDbiFEp0YEsCKHI (publico)
redirect_uri	https://oauth-pages-lab-9cz.pages.dev/oauth/callback/github (exata, HTTPS)
response_type	code
state	[REMOVIDO] (43 caracteres Base64URL)
code_challenge	[REMOVIDO] (43 caracteres Base64URL)
code_challenge_method	S256 (visivel)
scope	ausente (correto: omitido no fluxo do GitHub)
nonce	ausente (correto: nonce pertence apenas ao fluxo OIDC do Google)

Conferencias da Etapa 8 (15.2)

- OK - Estado HTTP 302.
- OK - A resposta cria o cookie __Host-oauth-tx (Path=/, HttpOnly, Secure, SameSite=Lax, Max-Age=600).
- OK - Location aponta para o GitHub (github.com/login/oauth/authorize).
- OK - response_type=code presente.
- OK - code_challenge_method=S256 presente.
- OK - A URL de retorno e a URL pages.dev exata.
- OK - Client Secret e code_verifier ausentes na URL e nos cabecalhos.
- OK - nonce e os escopos repo, user:email e offline_access ausentes.
- OK - Cache-Control: no-store na resposta.